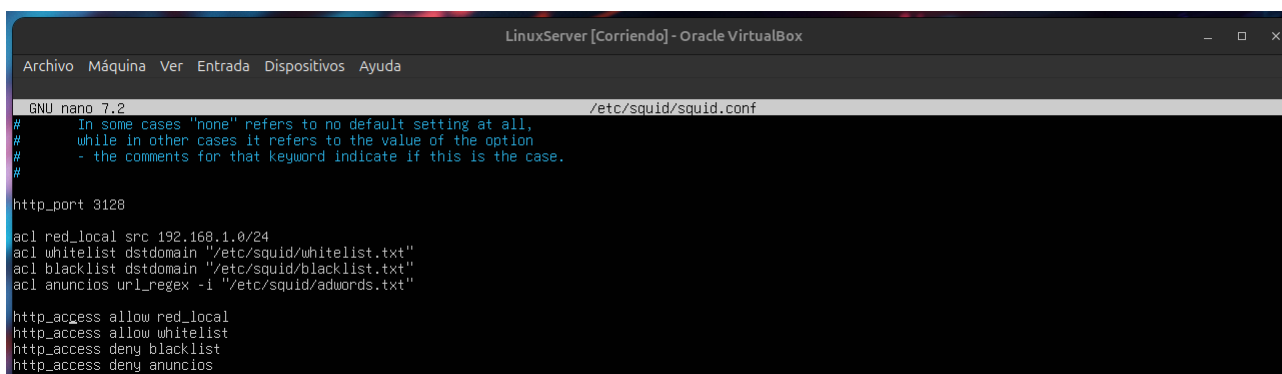


# Reto: Bloque 4 Día 27

## Fase: 1

Instalaremos y configuraremos Squid en un servidor Linux. Añadiremos listas negras y blancas para restringir el acceso a sitios sospechosos. Configuraremos reglas de filtrado para bloquear contenido malicioso y anuncios. E integraremos el proxy con DNS seguros para mejorar la seguridad.

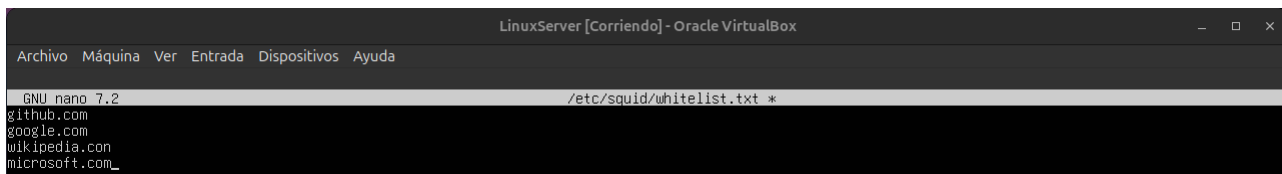
Instalaremos el proxy usando Squid. Cuando lo tengamos instalado deberemos editar el archivo squid.conf.



```
LinuxServer [Corriendo] - Oracle VirtualBox
Archivo  Máquina  Ver  Entrada  Dispositivos  Ayuda
GNU nano 7.2 /etc/squid/squid.conf
# In some cases "none" refers to no default setting at all,
# while in other cases it refers to the value of the option
# - the comments for that keyword indicate if this is the case.
#
http_port 3128
acl red_local src 192.168.1.0/24
acl whitelist dstdomain "/etc/squid/whitelist.txt"
acl blacklist dstdomain "/etc/squid/blacklist.txt"
acl anuncios url_regex -i "/etc/squid/adwords.txt"
http_access allow red_local
http_access allow whitelist
http_access deny blacklist
http_access deny anuncios
```

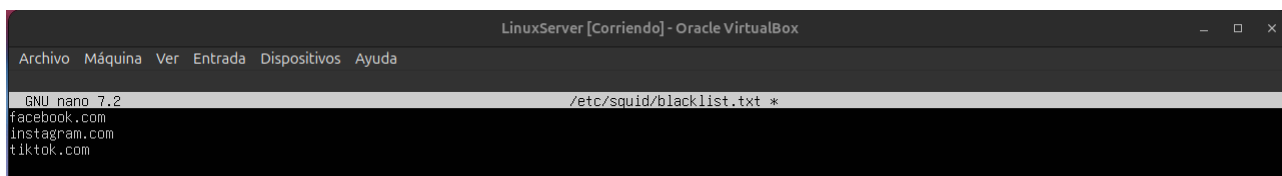
\* Esta sería una configuración básica. También hemos añadido la ubicación de las listas blancas, negras y el filtrado de seguridad.

A continuación deberemos crear la listas en formato .txt. Mostraremos las tres listas con algunos sitios de ejemplo.



```
LinuxServer [Corriendo] - Oracle VirtualBox
Archivo  Máquina  Ver  Entrada  Dispositivos  Ayuda
GNU nano 7.2 /etc/squid/whitelist.txt *
github.com
google.com
wikipedia.com
microsoft.com_
```

\* Esta sería la lista blanca.



```
LinuxServer [Corriendo] - Oracle VirtualBox
Archivo  Máquina  Ver  Entrada  Dispositivos  Ayuda
GNU nano 7.2 /etc/squid/blacklist.txt *
facebook.com
instagram.com
tiktok.com
```

\* Esta sería la lista negra.

```
LinuxServer [Corriendo] - Oracle VirtualBox
Archivo Máquina Ver Entrada Dispositivos Ayuda
GNU nano 7.2 /etc/squid/adwords.txt *
# Bloquear publicidad
doubleclick.net
googleadservices.com
adsense.com

# Bloquear trackers
facebook.com/tr
analytics.google.com
stats.g.doubleclick.net

# Palabras clave url
/ad
/banner
/popup
/malware
/phishing
```

\*Esta sería la lista para filtrar contenido sospechoso o malicioso.

Ahora integraremos los DNS seguros en Squid, usaremos uno de Cloudflare, Google y OpenDNS.

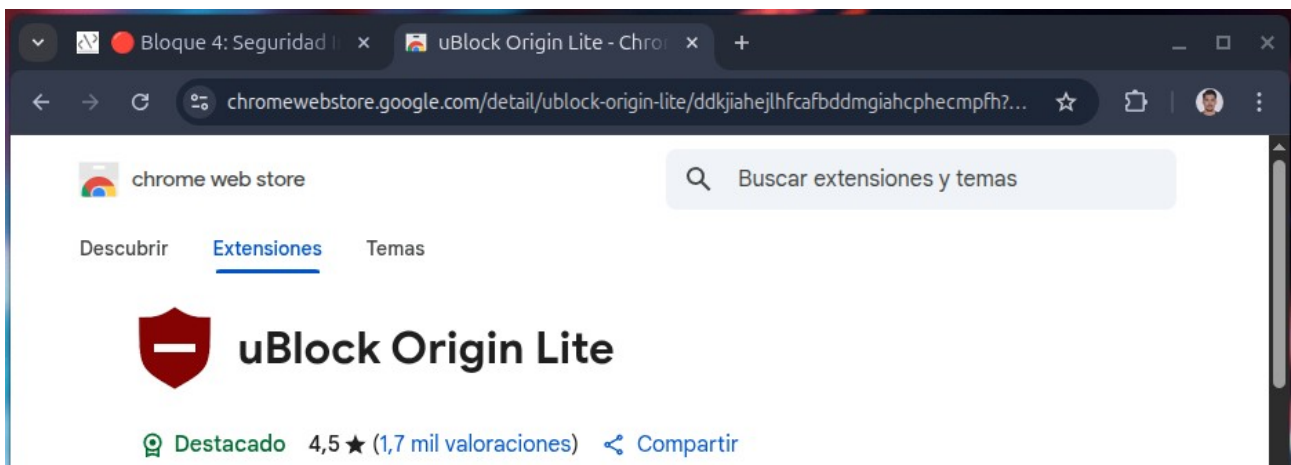
```
[Resolve]
# Some examples of DNS servers which may be used for DNS= and FallbackDNS=:
# Cloudflare: 1.1.1.1#cloudflare-dns.com 1.0.0.1#cloudflare-dns.com 2606:4700:4700::1111#cloudflare-dns.com 2606:4700:4700::1001#cloudflare-dns.com
# Google: 8.8.8.8#dns.google 8.8.4.4#dns.google 2001:4860:4860::8888#dns.google 2001:4860:4860::8844#dns.google
# Quad9: 9.9.9.9#dns.quad9.net 149.112.112.112#dns.quad9.net 2620:fe::fe#dns.quad9.net 2620:fe::9#dns.quad9.net
DNS=1.1.1.1 8.8.8.8
FallbackDNS=9.9.9.9
#Domain=
#DNSSEC=no
#DNSoverTLS=yes
#MulticastDNS=no
#LLMNR=no
#Cache=no-negative
#CacheFromLocalhost=no
#DNSStubListener=yes
#DNSStubListenerExtra=
#ReadEtcHosts=yes
#ResolveUnicastSingleLabel=no
#StaleRetentIonSec=0
```

\* Para añadir los DNS deberemos editar el archivo resolved.conf y poner la siguiente configuración. Y para terminar reiniciaremos el servicio systemd-resolved.

## Fase: 2

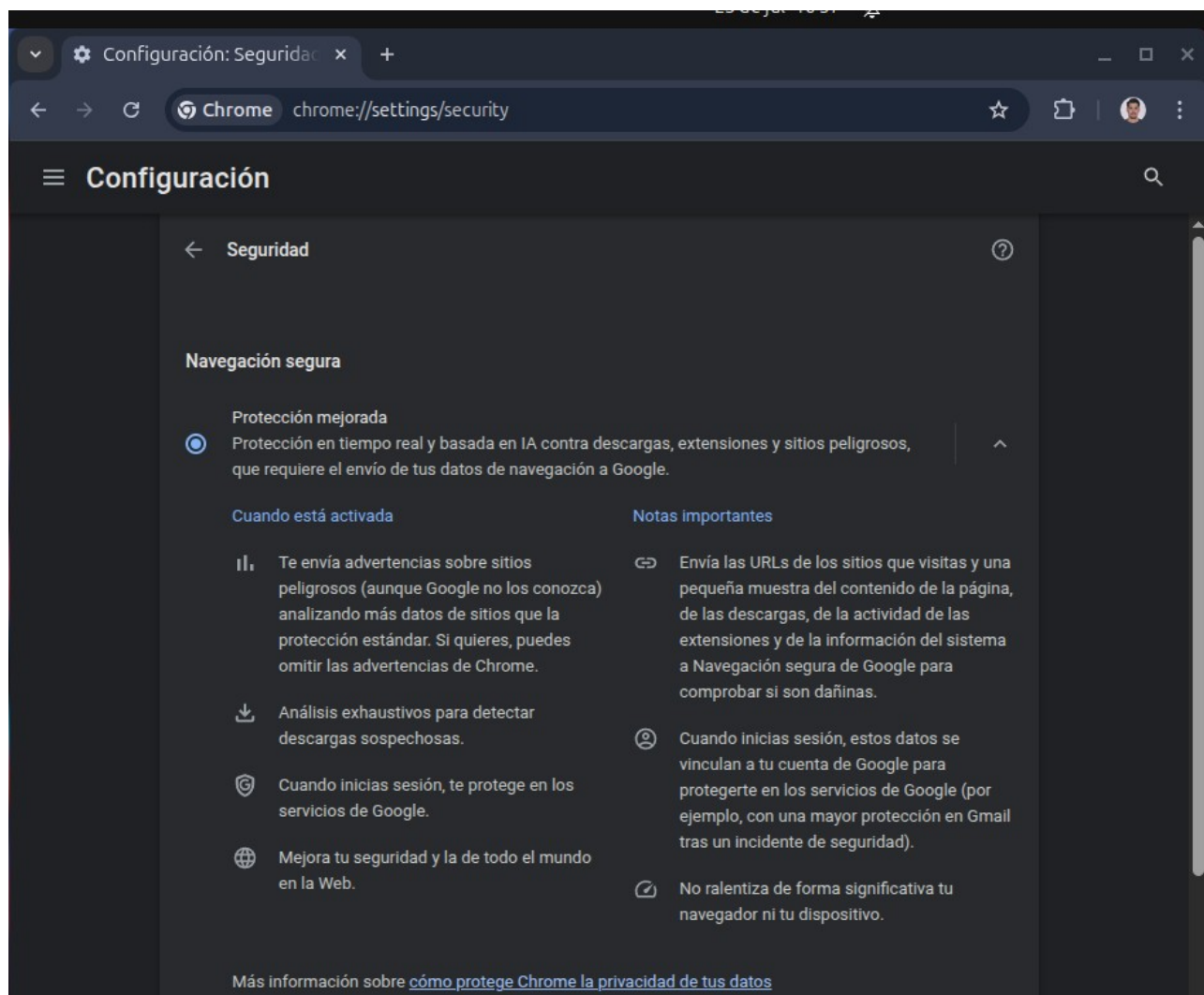
Instalaremos extensiones de seguridad en el navegador del cliente. Configuraremos bloqueadores de rastreo y scripts maliciosos. Ejecutaremos políticas de seguridad en navegadores para bloquear descargas. Y crearemos una simulación de ataque de phishing para concienciar a los empleados.

Utilizaremos el navegador Google Chrome para instalar uBlock Origin, ya que HTTPS Everywhere ya no se utiliza tanto.



\* Iremos al apartado de extensiones del navegador, buscaremos la extensión y la instalaremos.

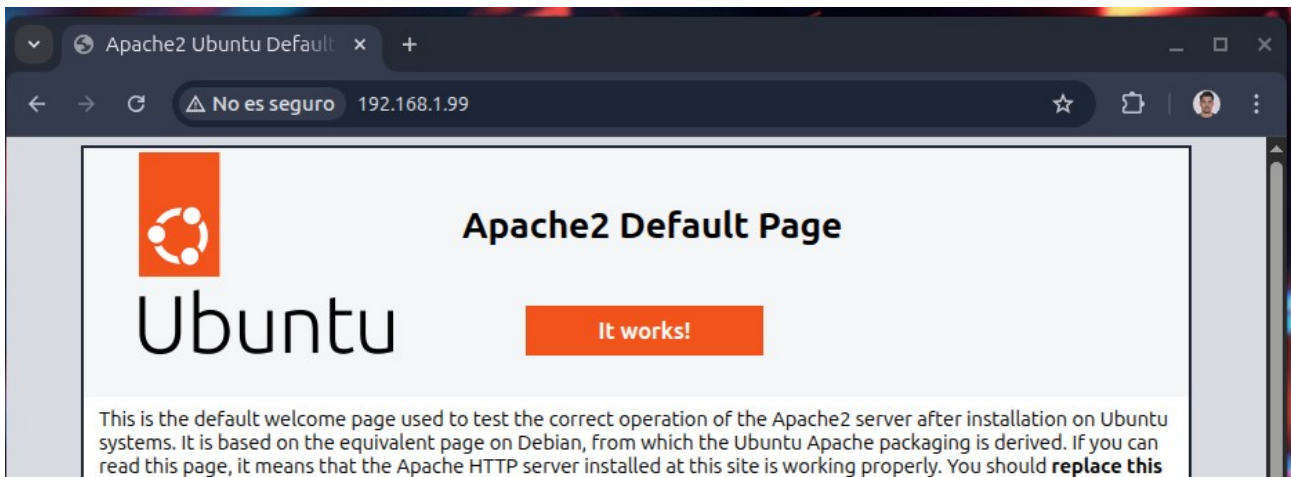
Para utilizar bloqueadores de rastreo Google Chrome, deberemos activar la Protección mejorada, en el apartado de seguridad de la configuración del navegador.



Para las políticas de seguridad, la protección mejorada, ya analiza si una descarga es sospechosa y la bloquea a no ser que la acepte el usuario. En el caso de Linux Server, usaremos AppArmor para crear perfiles y restringir la navegación.

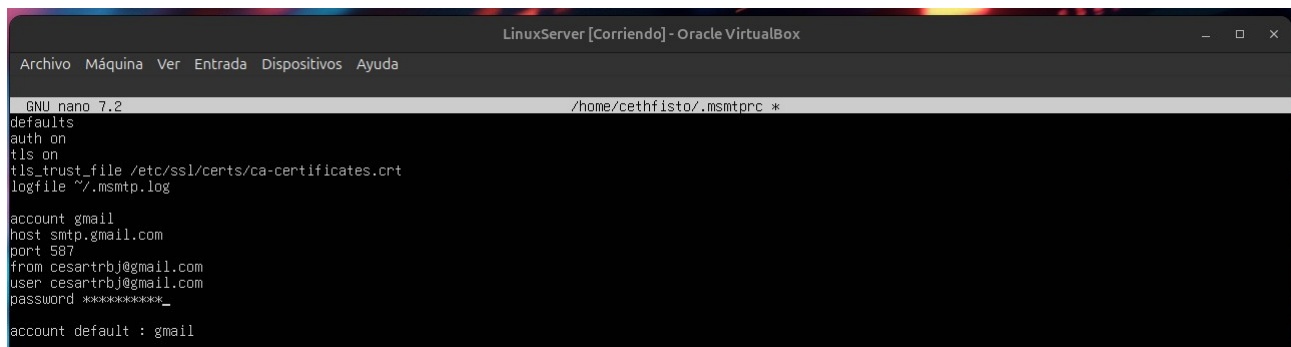
Ahora simularemos un ataque de phishing, crearemos un sitio falso con Apache2 y el servidor enviará un correo indicando que hay un problema a una cuenta de correo de la máquina cliente.

Instalaremos Apache2 en servidor Linux y verificaremos que está conectado a la red local la IP del servidor será 192.168.1.99.



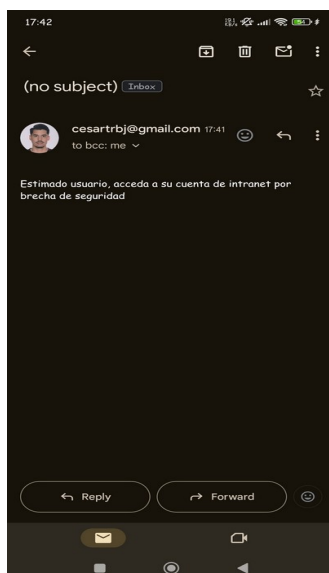
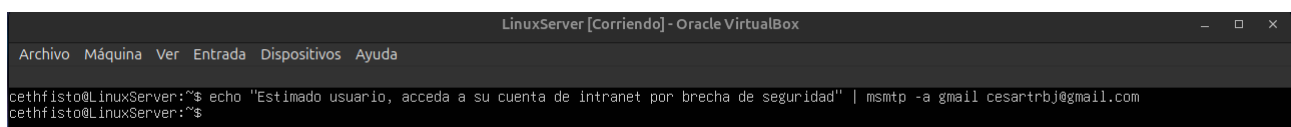
\* Imaginemos que esta web del servidor de Linux fuese una web calcada de algún sitio famoso. Por ejemplo: Facebook, Github, etc.

Ahora instalaremos la herramienta msmtprc y editaremos el archivo de configuración ~/.msmtprc.



\* Esta sería la configuración para poder enviar el correo a la cuenta en cuestión.

Acto seguido enviaremos el correo con el siguiente comando.

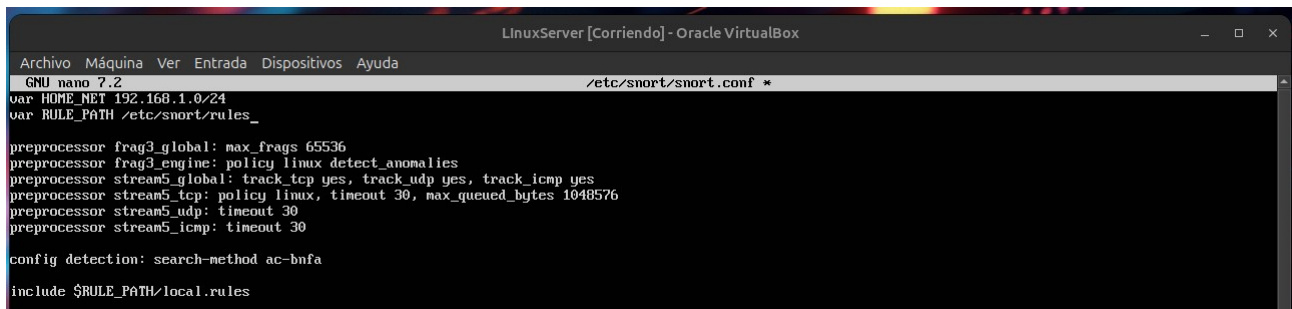


\* Una vez enviado el correo, la cuenta en cuestión lo recibirá. Cabe destacar que el correo recibido es un correo de prueba. Pero si sufrimos un ataque y consiguen datos sensibles sobre correos y contraseñas, podrán enviar correo con la cuenta corporativa para así, robar a clientes u otras sedes.

## Fase: 3

Configuraremos Snort para monitorizar los accesos. Revisaremos log en Squid y herramientas SIEM para detectar patrones peligrosos. Y analizaremos el tráfico con Wireshark, para identificar conexiones sospechosas.

Instalaremos Snort y configuraremos el archivo snort.conf para monitorizar nuestra interfaz de red (enp0s3).



```
LinuxServer [Corriendo] - Oracle VirtualBox
Archivo Máquina Ver Entrada Dispositivos Ayuda
GNU nano 7.2 /etc/snort/snort.conf *
var HOME_NET 192.168.1.0/24
var RULE_PATH /etc/snort/rules_

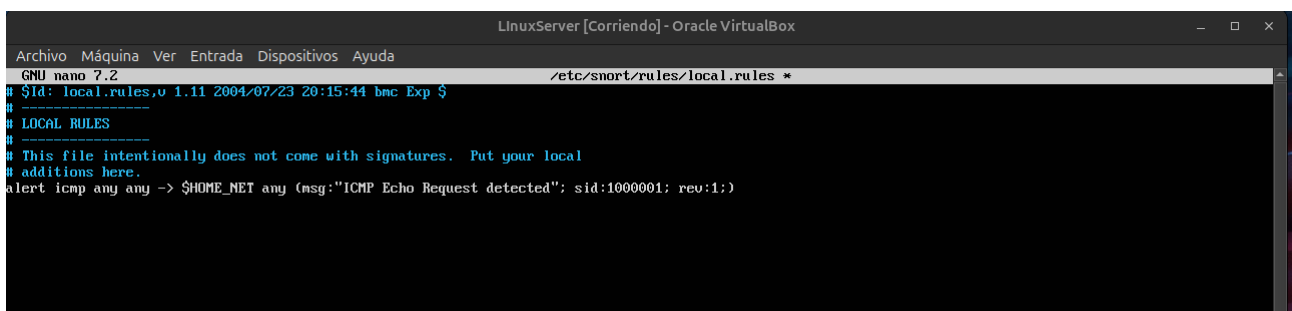
preprocessor frag3_global: max_frags 65536
preprocessor frag3_engine: policy linux detect_anomalies
preprocessor stream5_global: track_tcp yes, track_udp yes, track_icmp yes
preprocessor stream5_tcp: policy linux, timeout 30, max_queued_bytes 1048576
preprocessor stream5_udp: timeout 30
preprocessor stream5_icmp: timeout 30

config detection: search-method ac-bnfa

include $RULE_PATH/local.rules
```

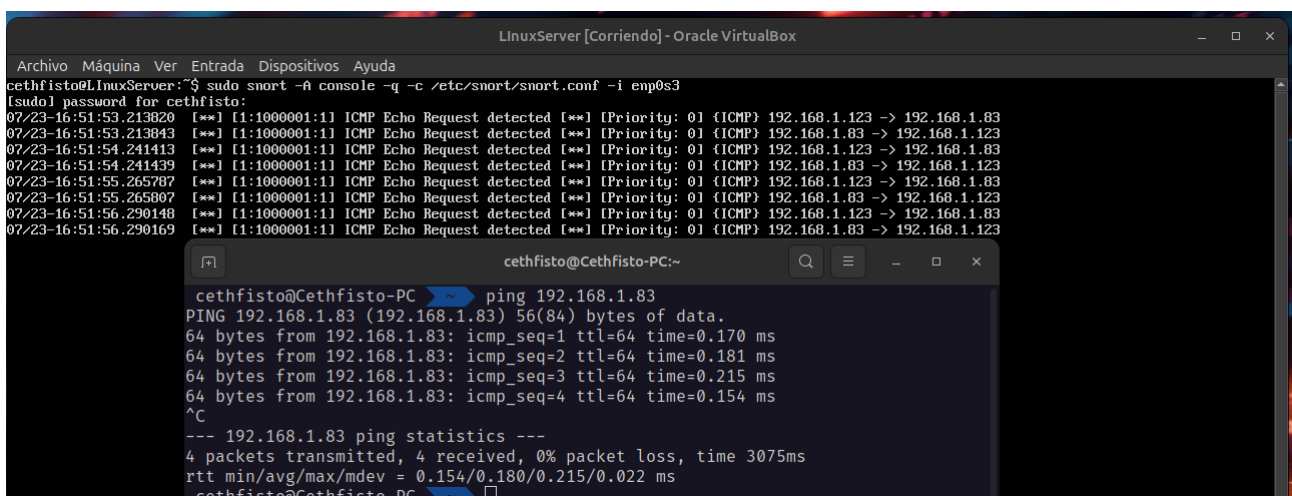
\* Esta sería la configuración mínima para monitorizar nuestra interfaz de red.

Después añadiremos las reglas básicas en el archivo local.rules.



```
LinuxServer [Corriendo] - Oracle VirtualBox
Archivo Máquina Ver Entrada Dispositivos Ayuda
GNU nano 7.2 /etc/snort/rules/local.rules *
# $Id: local.rules,v 1.11 2004/07/23 20:15:44 bmc Exp $
#
# LOCAL RULES
#
# This file intentionally does not come with signatures. Put your local
# additions here.
alert icmp any any -> $HOME_NET any (msg:"ICMP Echo Request detected"; sid:1000001; rev:1;)
```

\* Esta regla da una alerta cuando alguien hace ping en la red.



```
LinuxServer [Corriendo] - Oracle VirtualBox
Archivo Máquina Ver Entrada Dispositivos Ayuda
cethfisto@LinuxServer:~$ sudo snort -A console -q -c /etc/snort/snort.conf -i enp0s3
[sudo] password for cethfisto:
07/23-16:51:53.213820 [**] [1:1000001:1] ICMP Echo Request detected [**] [Priority: 0] (ICMP) 192.168.1.123 -> 192.168.1.83
07/23-16:51:53.213843 [**] [1:1000001:1] ICMP Echo Request detected [**] [Priority: 0] (ICMP) 192.168.1.83 -> 192.168.1.123
07/23-16:51:54.241413 [**] [1:1000001:1] ICMP Echo Request detected [**] [Priority: 0] (ICMP) 192.168.1.123 -> 192.168.1.83
07/23-16:51:54.241439 [**] [1:1000001:1] ICMP Echo Request detected [**] [Priority: 0] (ICMP) 192.168.1.83 -> 192.168.1.123
07/23-16:51:55.265787 [**] [1:1000001:1] ICMP Echo Request detected [**] [Priority: 0] (ICMP) 192.168.1.123 -> 192.168.1.83
07/23-16:51:55.265807 [**] [1:1000001:1] ICMP Echo Request detected [**] [Priority: 0] (ICMP) 192.168.1.83 -> 192.168.1.123
07/23-16:51:56.290148 [**] [1:1000001:1] ICMP Echo Request detected [**] [Priority: 0] (ICMP) 192.168.1.123 -> 192.168.1.83
07/23-16:51:56.290169 [**] [1:1000001:1] ICMP Echo Request detected [**] [Priority: 0] (ICMP) 192.168.1.83 -> 192.168.1.123

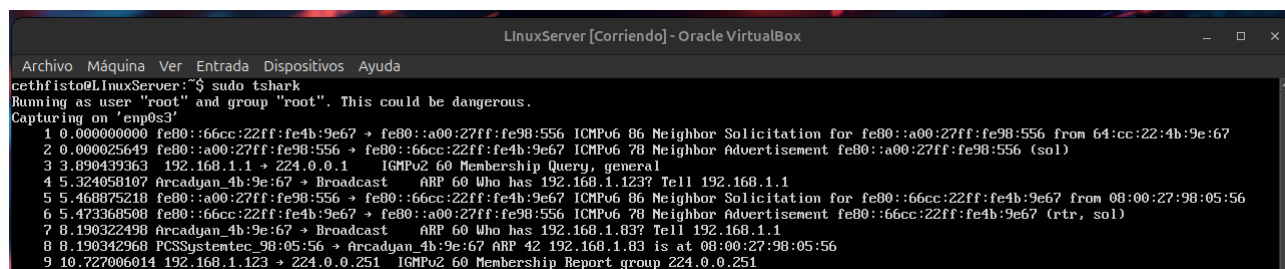
cethfisto@Cethfisto-PC:~$ ping 192.168.1.83
PING 192.168.1.83 (192.168.1.83) 56(84) bytes of data.
64 bytes from 192.168.1.83: icmp_seq=1 ttl=64 time=0.170 ms
64 bytes from 192.168.1.83: icmp_seq=2 ttl=64 time=0.181 ms
64 bytes from 192.168.1.83: icmp_seq=3 ttl=64 time=0.215 ms
64 bytes from 192.168.1.83: icmp_seq=4 ttl=64 time=0.154 ms
^C
--- 192.168.1.83 ping statistics ---
4 packets transmitted, 4 received, 0% packet loss, time 3075ms
rtt min/avg/max/mdev = 0.154/0.180/0.215/0.022 ms
cethfisto@Cethfisto-PC:~$
```

\* Como podemos ver Snort da avisos de los pings realizados desde nuestra máquina anfitrión.

Para revisar los log aplicaremos los mismo métodos que llevamos realizando en todos nuestros trabajos.

Para ver los logs de Squid tendremos que visualizar el archivo access.log. Usaremos los comando grep o awk para buscar IPs o URLs sospechosas. Y tendremos herramientas SIEM para tal cometido. Por ejemplo: Wazuh o Graylog.

Para analizar el tráfico en la red usaremos Wireshark.



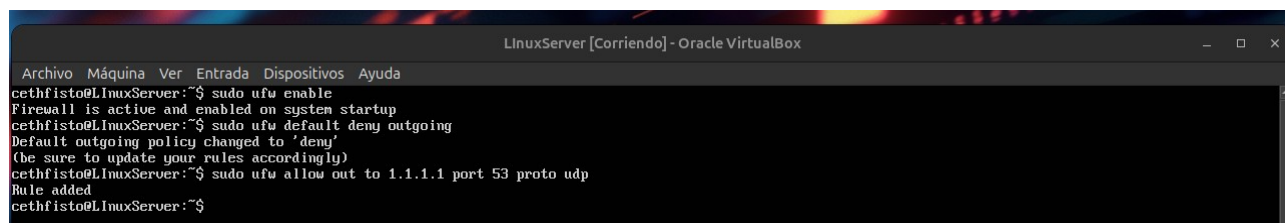
```
LinuxServer [Corriendo] - Oracle VirtualBox
Archivo Máquina Ver Entrada Dispositivos Ayuda
cethfisto@LinuxServer:~$ sudo tshark
Running as user "root" and group "root". This could be dangerous.
Capturing on 'enp0s3'
  1 0.000000000 fe80::66cc:22ff:fe4b:9e67 > fe80::a00:27ff:fe98:556 ICMPv6 86 Neighbor Solicitation for fe80::a00:27ff:fe98:556 from 64:cc:22:4b:9e:67
  2 0.000025649 fe80::a00:27ff:fe98:556 > fe80::66cc:22ff:fe4b:9e67 ICMPv6 78 Neighbor Advertisement fe80::a00:27ff:fe98:556 (sol)
  3 3.890439363 192.168.1.1 > 224.0.0.1 IGMPv2 60 Membership Query, general
  4 5.324058107 Arcadyan_4b:9e:67 > Broadcast ARP 60 Who has 192.168.1.123? Tell 192.168.1.1
  5 5.468875218 fe80::a00:27ff:fe98:556 > fe80::66cc:22ff:fe4b:9e67 ICMPv6 86 Neighbor Solicitation for fe80::66cc:22ff:fe4b:9e67 from 08:00:27:98:05:56
  6 5.473368508 fe80::66cc:22ff:fe4b:9e67 > fe80::a00:27ff:fe98:556 ICMPv6 78 Neighbor Advertisement fe80::66cc:22ff:fe4b:9e67 (rtr, sol)
  7 8.190322498 Arcadyan_4b:9e:67 > Broadcast ARP 60 Who has 192.168.1.83? Tell 192.168.1.1
  8 8.190342968 PCSSsystemtec_98:05:56 > Arcadyan_4b:9e:67 ARP 42 192.168.1.83 is at 08:00:27:98:05:56
  9 10.727006014 192.168.1.123 > 224.0.0.251 IGMPv2 60 Membership Report group 224.0.0.251
```

\* Como podemos ver Wireshark va analizando el tráfico y nos da información acerca de los dispositivos de la red, entre otros datos.

## Fase: 4

Configuraremos el firewall para bloquear accesos a sitios de alto riesgo. Crearemos una VPN para navegación segura. Y estableceremos políticas de acceso según los roles de la empresa.

Usaremos UFW para realizar una configuración de bloqueo a sitios de alto riesgos.



```
LinuxServer [Corriendo] - Oracle VirtualBox
Archivo Máquina Ver Entrada Dispositivos Ayuda
cethfisto@LinuxServer:~$ sudo ufw enable
Firewall is active and enabled on system startup
cethfisto@LinuxServer:~$ sudo ufw default deny outgoing
Default outgoing policy changed to 'deny'
(be sure to update your rules accordingly)
cethfisto@LinuxServer:~$ sudo ufw allow out to 1.1.1.1 port 53 proto udp
Rule added
cethfisto@LinuxServer:~$
```

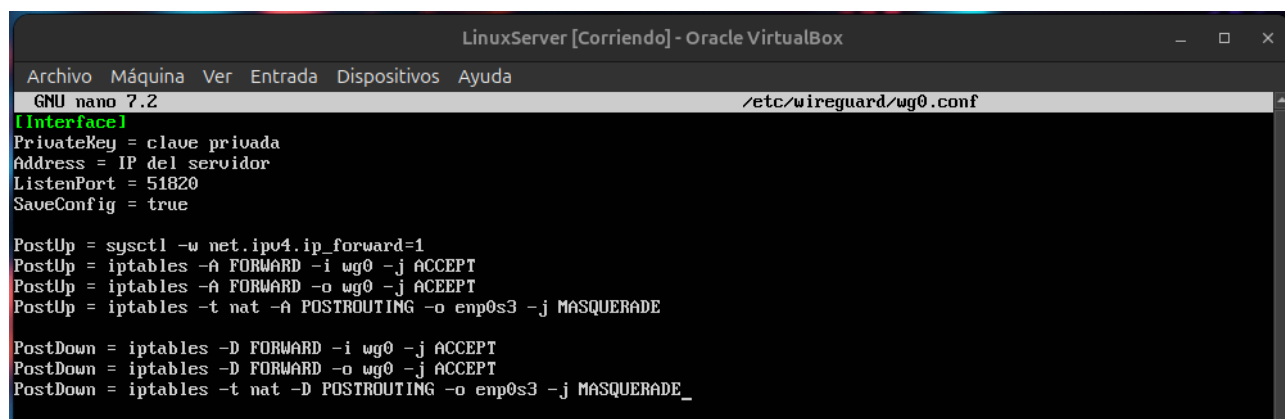
\* Está sería la configuración que se podría ajustas a nuestras necesidades.

Para crear una VPN, instalaremos Wireguard. Una vez instalado deberemos generar dos claves, una privada para el servidor y otra pública para los clientes.

```
wg genkey | tee server_private.key | wg pubkey > server_public.key
wg genkey | tee client_private.key | wg pubkey > client_public.key
```

\* Estos serían los comando para crear las claves.

Ahora deberemos configurar el servidor Wireguard para ello, crearemos un archivo llamado wg0.conf.



```
LinuxServer [Corriendo] - Oracle VirtualBox
Archivo Máquina Ver Entrada Dispositivos Ayuda
GNU nano 7.2 /etc/wireguard/wg0.conf
[Interface]
PrivateKey = clave privada
Address = IP del servidor
ListenPort = 51820
SaveConfig = true

PostUp = sysctl -w net.ipv4.ip_forward=1
PostUp = iptables -A FORWARD -i wg0 -j ACCEPT
PostUp = iptables -A FORWARD -o wg0 -j ACCEPT
PostUp = iptables -t nat -A POSTROUTING -o enp0s3 -j MASQUERADE

PostDown = iptables -D FORWARD -i wg0 -j ACCEPT
PostDown = iptables -D FORWARD -o wg0 -j ACCEPT
PostDown = iptables -t nat -D POSTROUTING -o enp0s3 -j MASQUERADE_
```

\* Esta sería la configuración para el servidor.

Cabe destacar que también deberemos configurar el cliente Wireguard. Después de configurar ambos equipos, lo iniciamos en ambas máquinas.

Para las políticas por roles podemos aprovechar Squid para limitar o permitir según el departamento a ciertos contenidos. Deberemos volver a editar el archivo squid.conf.

```
acl admin src "/etc/squid/admin_ips.txt"
acl sitios_permitidos dstdomain "/etc/squid/sitios_admin.txt"
http_access allow admin sitios_permitidos
```

\* Estas líneas de comando servirían para configurar el departamento de administración. Deberemos añadir los sitios permitidos en el archivo sitios\_admin.txt. Y hacer lo así sucesivamente con los otros departamentos.

## Fase: 5

Justificaremos como estas medidas protegen a CodeArts y optimizan la seguridad.

Esta medidas aportaran una serie de mejoras de seguridad a la empresa de CodeArts:

- Protección frente amenazas externas: usando squid, evitamos que los usuarios accedan a sitios sospechosos o maliciosos. Y con el uso de DNS impedimos la resolución de dominios sospechosos, bloqueando y reduciendo los intentos de conexión a server maliciosos.
- Minimización del riesgo frente ataque phishing: al usar extensiones de seguridad en los navegadores, nos protegemos frente anuncios maliciosos y conexiones no cifradas.
- Monitorización en tiempo real: con el uso de Snort y Wireshark, podemos detectar patrones sospechosos de navegación, conexiones no autorizadas y filtraciones de datos.
- Acceso por roles: la división de accesos a sitios web según el departamento o roles, evita distracciones y reduce la exposición a amenazas.

- Optimización del ancho de banda: usando squid podremos analizar el contenido web frecuente, limitando el consumo innecesario de ancho de banda y mejorando la carga de sitios autorizados. Esto da lugar a una mejora de rendimiento de la red en general.

- Navegación segura desde ubicaciones remotas: al usar una VPN, nos aseguramos que los usuarios que trabajen en remoto accedan a internet de forma segura y vigilada, como si estuvieran dentro de la red empresarial. Esto evita ataques en puntos de red públicos o sospechosas.